

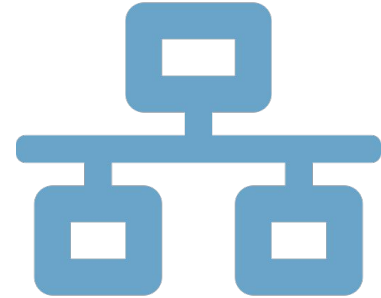
BSc (Hons) Computer Science with Software Engineering
Coventry University (CU) - National Institute of Business Management (NIBM)

NB5004CEM - Level 5 - 20 Credits

Network & System Security



NB5004CEM Cybersecurity - Session 7





S7 Network & System Security

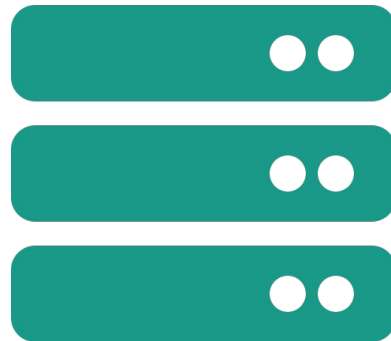
The final layer session - completing the five-layer framework



Session 7 Overview

The final layer. After today, all five layers are covered.

- Evaluate firewall, WAF and DMZ controls (LO1)
- Judge OS hardening via CIS benchmarks (LO3)
- Explain why secrets management spans three layers (LO1)
- Apply the cloud shared-responsibility model (LO3)
- Complete all five layers - unlocking Session 8's SRS (LO1, LO3)



Five Layers, One Framework - What's Left



Every SRS requirement and every Part B section traces to one of five layers.

Layer	Status	Covered In
IAM	Complete	Session 4 - Session 5
Application	Complete	Session 6
Data	Complete	Session 3 (+ backups/keys today)
Network	Today	Session 7
System	Today	Session 7

Two layers left - both fall in this session. After today, the full stack is evaluable.

Firewalls: What They Catch, What They Miss



- **Property:** reduces exposure - supports Confidentiality and Availability
- **Mechanism:** inspects packet headers, connection state and rule sets
- **Stateful firewalls** track connections; **stateless firewalls** check each packet alone
- **Misses:** cannot see inside encrypted traffic, or spot an application logic flaw
- **Hook:** firewall placement and rules underpin NET-01 and NET-02

Analogy

A firewall is a building's reception desk: it checks who is allowed through the door and which floor they claim to be visiting. It cannot tell whether the visitor, once inside, is lying about their business.

The DMZ: Trust Boundaries Made Concrete



- **Property:** contains Confidentiality and Availability damage if the edge is breached
- **Mechanism:** a separate zone between the public internet and internal systems
- **Web servers and reverse proxies belong here; databases and internal services never do**
- **This is Session 2's trust boundary, drawn as an actual architecture pattern**
- **Hook:** DMZ placement is evidence for NET-01 (no public DB)

Analogy

The DMZ is a hotel lobby, not the guest floors. Strangers can wait in the lobby; they never get a room key that opens a floor directly.

WAF: One Control Among Many



Property: Integrity - blocks known exploit patterns before they reach the application.

What It Catches

- Known attack signatures
- Injection patterns
- Malformed requests

What It Misses

- Logic flaws
- Zero-day exploits
- Authenticated abuse

Hook: WAF evidence feeds NET-02 and B3 (network and platform security). One control among many - never a complete solution.

Rate Limiting & DDoS Resilience

- **Property:** protects Availability directly - the service must stay reachable under load
- **Mechanism:** throttles requests per endpoint, per user, per IP address
- **DDoS resilience:** absorbing or filtering volumetric abuse before it exhausts the service
- **Misses:** sophisticated slow, low-volume abuse can still slip under the threshold
- **Hook:** rate limiting and DDoS resilience are evidence for NET-02

Analogy

Rate limiting is a bouncer capping how fast people enter a venue. It keeps the room usable even when a crowd is trying to force its way in all at once.

Micro-segmentation: Containing the Breach



- **Property:** contains damage to Confidentiality and Availability after a breach begins
- **Mechanism:** the network is divided into zones, each with its own access controls
- **Assumption:** something will eventually get in - the question is how far it can travel
- **Misses:** does not prevent the initial compromise, only its spread
- **Hook:** micro-segmentation is evidence for NET-03

Analogy

Micro-segmentation is fire doors between rooms. A fire that starts in one room is still a fire - but it doesn't get to burn down the whole building.

Network Controls At a Glance

No control catches everything - evaluation means knowing each gap.

Control	Catches	Misses	Property	SRS
Firewall	Headers, state, rules	Encrypted payloads, logic flaws	Confid., Avail.	NET-01
DMZ	Exposure of internal systems	Flaws inside the exposed service	Confidentiality	NET-01
WAF	Signatures, injection patterns	Zero-days, authenticated abuse	Integrity	NET-02
Rate/DDoS	Volumetric abuse, brute force	Slow, low-and-slow attacks	Availability	NET-02
Micro-seg.	Lateral movement after breach	The initial breach itself	Confid., Avail.	NET-03

Together, correctly evidenced, these satisfy NET-01, NET-02 and NET-03.

OS Hardening & CIS Benchmarks



OS Hardening (the principle)

- Remove unnecessary services and close unused ports
- Disable default accounts; install only what's needed
- Every extra component is attack surface

CIS Benchmarks (the method)

- Published hardening checklists per OS / software
- An evaluator compares live config to the benchmark
- Deviations from baseline are recorded as findings

Property: Confidentiality + Availability (smaller System-layer surface) | Hook: SYS-01

Patch Management: The Risk Window



- **Property:** timely patching protects Confidentiality, Integrity and Availability together
- The gap between disclosure and patching is a measurable risk window
- Unpatched systems are the most common initial access vector in real breaches
- This is the CVE thread running through the whole module, made operational
- **Hook:** patch currency is evidence for SYS-01

Analogy

A disclosed vulnerability is a published spare key. Every day it sits unpatched is another day that key is out on the street.

Hardened Images: Baked-In Security



- **Property:** consistent build-time hardening protects Availability and Integrity
- **Mechanism:** pre-configured OS images with hardening applied before deployment
- **Correct approach** for cloud and containers - hardening travels with the image, not a person's memory
- **Misses:** an image is only as good as its last rebuild - stale images drift out of date
- **Hook:** hardened images are evidence for SYS-01

Coursework note: state which base image your coursework system assumes, and how you'd verify it was hardened.

System Controls At a Glance

All four converge on one requirement class - SYS-01 - from different angles.

Control	Verifies	Limits	SRS
OS Hardening	Unnecessary components removed/disabled	Doesn't stop app-layer logic flaws	SYS-01
CIS Benchmarks	Configuration against a published baseline	Only as current as the benchmark used	SYS-01
Patch Mgmt.	Time-to-patch against disclosure date	Zero-days before a patch exists	SYS-01
Hardened Images	Consistent build-time hardening	Drift if the image itself goes stale	SYS-01

An evaluator's question is always the same: compared to what baseline, and how current is the evidence?

Secrets Management Spans Layers



Why Env Vars Fail

- Visible in process listings
- Logged accidentally by monitoring tools
- Committed to version control by mistake

What a Vault Provides

- Centralised storage and access control
- Audit logging - an Accountability control
- Automatic rotation

Property: Confidentiality + Accountability. Also an IAM concern - vault access must itself be authenticated.
Hook: APP-02, DATA-02. Pays back Session 3's hardcoded-keys warning.

KEY CONCEPT

Responsibility Doesn't Disappear In the Cloud - It Moves

In IaaS, PaaS and SaaS, some security work always belongs to the provider and some always belongs to you. Move to a more managed service and the provider's share grows - but your share never reaches zero. Misreading this boundary is one of the most common causes of real cloud breaches.



Shared Responsibility: Who Owns What



IaaS

Most

- Customer owns OS, application and data
- Provider owns infrastructure and hypervisor

e.g. AWS EC2, Azure VMs

PaaS

Some

- Customer owns application and data
- Provider owns runtime and infrastructure

e.g. Heroku, Elastic Beanstalk

SaaS

Least

- Customer owns data, access, config
- Provider owns most of the stack

e.g. Google Workspace, Salesforce

Why This Constrains Your SRS



- **Property: fundamentally an Accountability question - who is answerable for a given control?**
- **A requirement you write must be something you can verify, and the owner can action**
- **Writing a control the provider owns is scope creep - it does not belong in your SRS**
- **First step for Part B: state your system's deployment model and what you own**
- **Hook: this directly seeds B1 (target environment) in Session 8**

Interactive: Shared-Responsibility Slider



- **Open**
NB5004CEM_S7_NetworkSystem_Demo_SharedResponsibilitySlider.html - works offline, no install
- **Drag the slider from IaaS to PaaS to SaaS**
- **Watch the ownership boundary move down the stack - it never reaches zero for either side**
- **Try it against your own coursework system's deployment model before Session 8**

Analogy

This is the one moving line in the whole session. Everything else on the network and system layers is a fixed control; this boundary genuinely shifts depending on the service model you choose - which is exactly why it earns its own interactive demo.

Coursework Synthesis: What S7 Unlocks



- **NET-01, NET-02, NET-03 and SYS-01 are now fully writable - and feed B3 (network and platform security)**
- **Secrets management feeds APP-02 and DATA-02**
- **Shared responsibility directly seeds B1 (target environment)**
- **All five layers - IAM, Network, System, Application, Data - are now covered**
- **Session 8 turns this into a testable SRS, requirement by requirement**

Activity: Cloud Architecture Review

Given a cloud architecture diagram:

- **1. Identify misconfigurations using the provided checklist**
- **2. Map each finding to a SRS ID (NET-01/02/03, SYS-01)**
- **3. Identify which properties are violated**
- **4. Decide: provider's failure or the customer's?**



Lab: CVE Hunt for Your Domain

Find 2 recent CVEs for an infrastructure component in YOUR domain:

- 1. Read the CVSS score
- 2. Identify which layer it affects
- 3. Check if the diagram uses the affected version
- 4. State the SRS requirement that reduces the risk

Worked example first - then it's your domain, your search.



Questions & Answers

Two layers down. Five layers complete. Session 8: writing the SRS.



Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I do make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

@ Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic. This should constitute a 'fair use' of any such copyrighted material.

Last modified: 3 Jul 2026